Security Assessment Report

TARGET URL	https://quickbriks.com/
SCAN ID	–
GENERATED	2026-05-27 07:55 UTC

0/100 Security Score — Critical Risk

Executive Summary

43 security issues were detected across this scan. These findings should be reviewed and remediated promptly.

HTTP Header Issues	11
OWASP ZAP Alerts	20
Technology Exposure	1
Sensitive File Exposure	3

Detailed Findings

✓ SQL Injection Analysis
No issues detected

✓ No SQL injection vulnerabilities were detected.

✓ SSL/TLS Certificate
Valid certificate

Issuer	Let's Encrypt
Subject	quickbriks.com
Expires	Aug 18 14:11:06 2026 GMT
Protocol	TLSv1.3

✗ HTTP Header Security
11 issues found

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

X-XSS-Protection should be set to 0 — Low

Value: 1; mode=block — the legacy XSS filter causes its own vulnerabilities in old IE/Edge.

Missing cross-origin-opener-policy — Medium

cross-origin-opener-policy was not present in the response.

Missing cross-origin-resource-policy — Low

cross-origin-resource-policy was not present in the response.

Information disclosure via x-powered-by — Low

x-powered-by: PHP/8.3.31

Information disclosure via server — Low

server: railway-edge

Cookies missing HttpOnly flag — Medium

XSRF-TOKEN, laravel_session

Cookies missing SameSite attribute — Low

XSRF-TOKEN, laravel_session

Weak CSP directive: 'unsafe-inline' — Medium

CSP contains "unsafe-inline" which significantly weakens XSS protection.

Weak CSP directive: 'unsafe-eval' — Medium

CSP contains "unsafe-eval" which significantly weakens XSS protection.

Weak CSP directive: data: — Medium

CSP contains 'data:' which significantly weakens XSS protection.

CSP missing object-src — Low

Add object-src 'none' to block Flash and other plugin execution.

- Set X-XSS-Protection: 0 (the CSP header is the correct defence).
- Add Cross-Origin-Opener-Policy: same-origin to prevent Spectre-style cross-origin attacks.
- Add Cross-Origin-Resource-Policy: same-origin to prevent cross-site resource loading.
- Remove X-Powered-By — it discloses the server technology stack.
- Suppress or genericise the Server header to avoid version disclosure.
- Mark session cookies with HttpOnly to prevent JavaScript access.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

- Set SameSite=Lax or SameSite=Strict on cookies unless cross-site use is required.
- Remove "unsafe-inline" from your Content-Security-Policy.
- Remove "unsafe-eval" from your Content-Security-Policy.
- Remove 'data:' from your Content-Security-Policy.

WordPress Security

Not a WordPress site

No WordPress installation detected on this target.

✗ OWASP ZAP Analysis

20 alerts

Tech Detected - HSTS	Informational
Strict-Transport-Security	
Tech Detected - Inertia.js	Informational
X-Inertia	
Tech Detected - Laravel	Informational
laravel_session	
Tech Detected - PHP	Informational
PHP/8.3.31	
Session Management Response Identified	Informational
laravel_session	
Re-examine Cache-control Directives	Informational
no-cache, private	
CSP: Wildcard Directive	Medium
default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdnjs.cloudflare.com https://cdn.jsdelivr.ne	
CSP: script-src unsafe-inline	Medium
default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdnjs.cloudflare.com https://cdn.jsdelivr.ne	
CSP: style-src unsafe-inline	Medium
default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdnjs.cloudflare.com https://cdn.jsdelivr.ne	
CSP: script-src unsafe-eval	Medium

default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdnjs.cloudflare.com https://cdn.jsdelivr.ne

Cookie No HttpOnly Flag — Low

Set-Cookie: XSRF-TOKEN

Modern Web Application — Informational

<script type="module" src="https://quickbriks.com/build/assets/app-CefaF8Oe.js" data-navigate-track="reload"></script>

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) — Low

X-Powered-By: PHP/8.3.31

Tech Detected - Tailwind CSS — Informational

--tw-rotate

Strict-Transport-Security Header Not Set — Low

HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying us

X-Content-Type-Options Header Missing — Low

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Ex

Strict-Transport-Security Header Not Set — Low

HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying us

X-Content-Type-Options Header Missing — Low

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Ex

CSP: Wildcard Directive — Medium

default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdnjs.cloudflare.com https://cdn.jsdelivr.ne

CSP: script-src unsafe-inline — Medium

default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdnjs.cloudflare.com https://cdn.jsdelivr.ne

✓ Malicious Content Analysis

No threats detected

✓ No malicious indicators detected.

Threat Score: 0/10

✓ Cross-Site Scripting (XSS)

No reflected XSS detected

✓ No reflected XSS vectors detected in tested parameters.

Content-Security-Policy header missing — Medium

No CSP detected — add one as a defence-in-depth measure

✗ Technology Fingerprinting

1 actionable issue found

Javascript Frameworks	Svelte
Programming Languages	PHP

Technology stack exposed via X-Powered-By — Low

PHP/8.3.31

Detected: Php — Info

Identified in the tech stack.

- Remove the X-Powered-By header to reduce information exposure.
- Ensure PHP version is current and not end-of-life.

✗ Sensitive File Exposure

3 paths exposed

robots.txt exposed (check Disallow paths)

SEVERITY	Low
URL	https://quickbriks.com/robots.txt
SIZE	24 bytes
PREVIEW	`User-agent: * Disallow:`

.htaccess exposed (URL rewrite rules)

SEVERITY	Medium
URL	https://quickbriks.com/.htaccess
SIZE	740 bytes
PREVIEW	`Options -MultiViews -Indexes RewriteEngine On # Handle Authorization Header RewriteCond %{HTTP:Authorization} . RewriteRule .* - [E=HTTP_AUTHORIZATION:%{HTTP:Authorization}] # Handle X-XSRF-Token Header RewriteCond %{HTTP:x-xsrf-token} . RewriteRule .* - [E=HTTP_X_XSRF_TOKEN:%{HTTP:X-XSRF-Token}] # Redirect Trailing Slashes If Not A Folder... RewriteCond %{REQUEST_FILENAME} !-d RewriteCond %{REQUE`

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

Admin login exposed

SEVERITY	Low
URL	https://quickbriks.com/admin/login
SIZE	42,821 bytes

• Block access to sensitive files via Nginx `deny all` or Apache `Require all denied` directives.

✓ **Downloaded Artifact Malware Analysis**
No malware indicators detected

✓ No malware indicators were detected in same-origin downloadable artifacts.

✗ **DNS Security (SPF / DMARC / DKIM)**
7 issues

No SPF record — High

No SPF TXT record found for quickbriks.com. Attackers can send spoofed email appearing to come from this domain.

DMARC policy set to none (monitor only) — Medium

p=none means spoofed emails are not rejected or quarantined — only reported.

DMARC has no reporting address — Low

No rua or ruf tag — you will not receive aggregate or forensic failure reports.

DMARC subdomain policy not set — Low

Without sp=, subdomains inherit the root policy which may not be intended.

No DKIM record found (common selectors checked) — Medium

None of the common DKIM selectors (default, google, mail, k1, selector1, selector2, dkim, email, smtp) returned a DKIM1

DNSSEC not enabled — Low

No DS or DNSKEY records found for quickbriks.com. DNSSEC prevents DNS cache poisoning attacks.

No CAA record — Low

No CAA record for quickbriks.com. Any CA can issue certificates for this domain.

• Add an SPF record: v=spf1 include:<your-mail-provider> -all

• Upgrade DMARC policy from p=none to p=quarantine, then p=reject once you have confirmed legitimate mail flows.

• Add rua=mailto:dmarc-reports@yourdomain.com to receive DMARC aggregate reports.

• Add sp=reject to your DMARC record to apply the same policy to all subdomains.

- Configure DKIM signing on your mail server and publish the public key as a TXT record at <selector>._domainkey.<domain>.
- Enable DNSSEC for your domain — configure it at your DNS registrar and publish DS records.
- Add CAA records to restrict which certificate authorities may issue certificates for your domain. Example: 0 issue "letsencrypt.org"

✓ **Open Redirect**
Pass

✓ No open redirect vulnerabilities detected.

✓ **Subdomain Takeover**
Pass

✓ No dangling CNAMEs or unclaimed service fingerprints found across 2 subdomains.

Conclusion & Recommended Next Steps

1. HTTP Headers	Add missing security headers (CSP, HSTS, X-Frame-Options, etc.).
2. ZAP Alerts	Triage each alert and patch confirmed vulnerabilities.
3. Technology Exposure	Patch outdated client libraries, disable directory indexes, and reduce version disclosure.
4. File Exposure	Block sensitive paths in the web server and rotate any exposed credentials.
5. DNS Security	Configure SPF (-all), DMARC (p=quarantine or reject), DKIM signing, and CAA records.

Developer Best Practices

- Adopt secure-by-default output encoding and enforce a strict Content-Security-Policy across all templates and SPAs.
- Standardize security headers and cookie flags in a shared middleware layer so new vibecoded pages inherit safe defaults.
- Keep source, backup, env, and debug artifacts out of the web root, and validate deployment bundles before publish.
- Use authenticated code review and protected branches even for AI-generated code; fast generation increases the need for release guardrails.
- Add pre-production checks for secrets, dependency risk, headers, and exposed debug routes before every deployment.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.